SQL 注入漏洞与防护作业报告

任务 1：数据库与查询条件基础说明

以 DVWA 的用户 ID 查询功能为例，对基础链路进行说明：

页面输入与数据库查询的关联

DVWA 的用户 ID 查询功能，需要根据用户输入的 ID 值从数据库中读取对应用户信息并展示。页面输入的 ID 是查询条件的来源，数据库是数据的存储载体，二者通过 SQL 查询语句实现联动。

最小业务链路

用户输入 ID → 后端接收输入并拼接 SQL 语句 → 数据库执行查询 → 返回结果 → 页面展示用户信息

示例：输入 1 时，后端执行：

sql

```
SELECT first_name, last_name FROM users WHERE user_id = '1';
```

用户输入进入查询条件的方式

后端代码直接将用户输入拼接到 SQL 语句中，未做任何安全处理。输入内容会被当作 SQL 语句的一部分参与执行。

SQL 注入可能性的成因

由于输入未经过滤、未使用参数化处理，攻击者可通过输入 SQL 语法字符（如单引号'）提前闭合字符串，改变原有 SQL 结构，从而注入自定义逻辑，实现越权查询、数据泄露等攻击。这是典型的输入污染查询结构导致的漏洞。

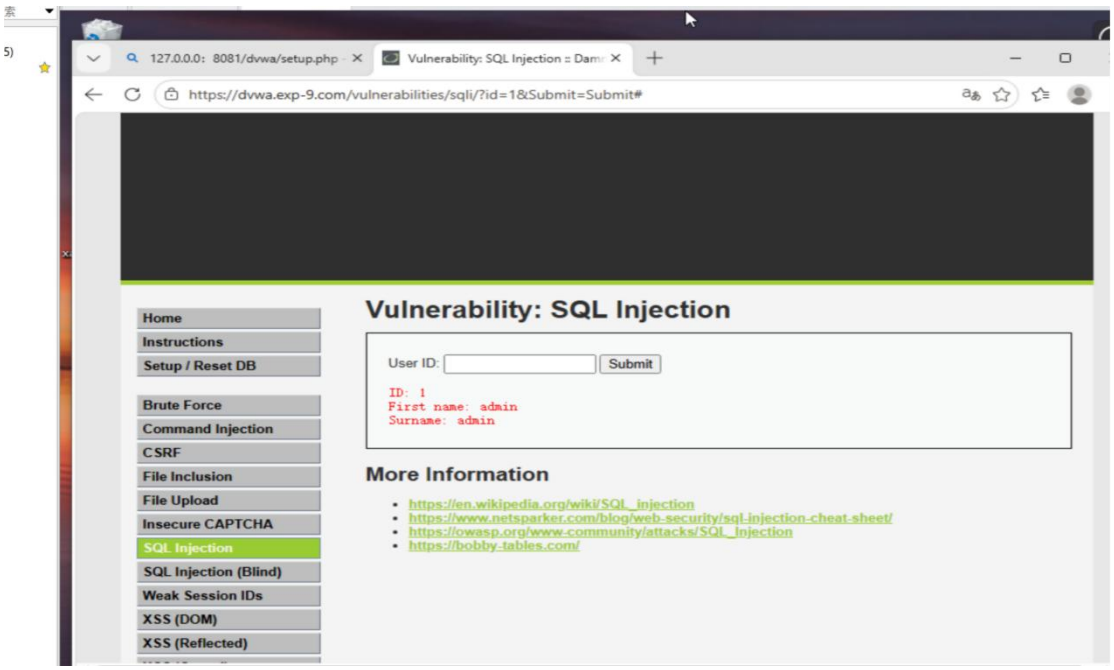
任务 2：DVWA SQL Injection Low 现象记录

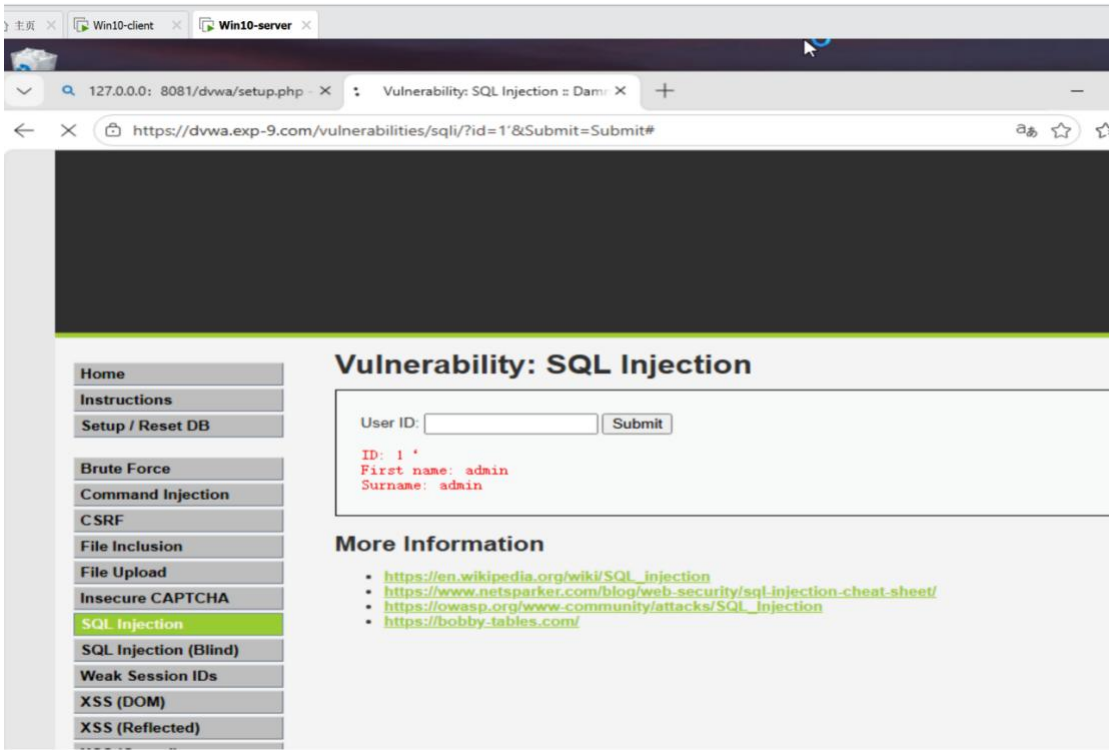
1. 实验页面与目标

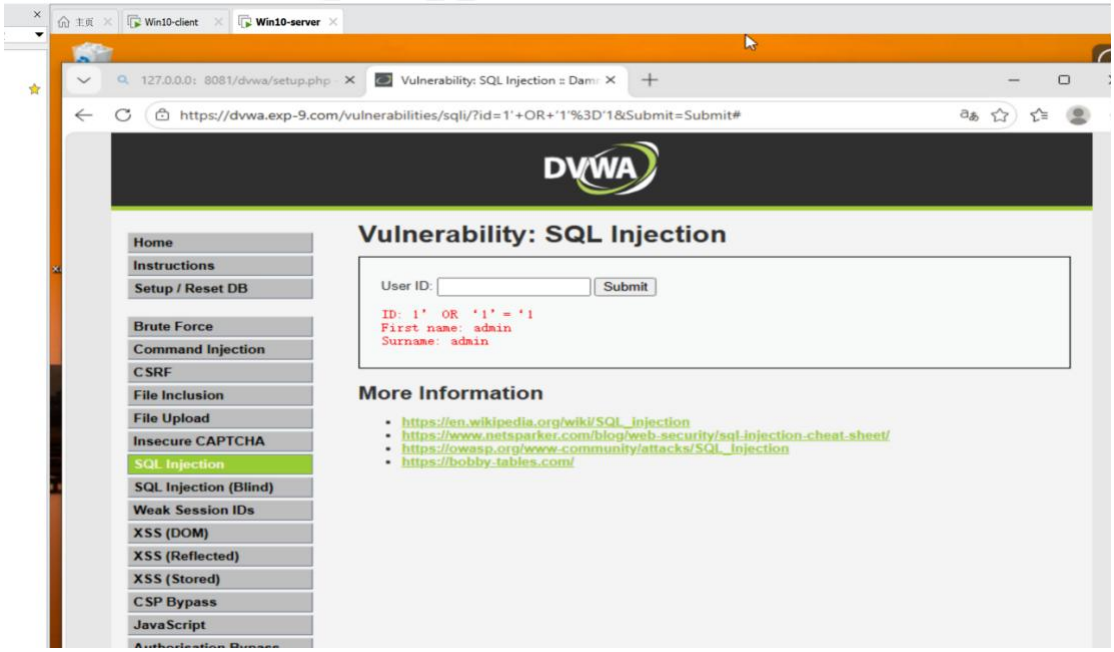
实验页面：DVWA SQL Injection 模块，安全级别：Low

实验目标：观察不同输入的页面响应，验证 SQL 注入漏洞存在

2. 普通输入与异常输入对比







输入内容	预期正常行为	实际返回结果
1	返回 ID=1 的用户信息	First name: admin, Surname: admin
1’	无结果或提示无效 ID	数据库语法错误信息
1’ OR ’1’=’1	无结果或提示无效 ID	返回全部用户数据
2	返回 ID=2 的用户信息	First name: Gordon, Surname: Brown

3. 返回结果的差异

正常输入仅返回单条匹配数据。

输入 1'触发数据库语法报错，暴露后端拼接逻辑。

注入语句 1' OR '1'='1 使查询条件恒真，返回全部用户数据，查询逻辑被完全篡改。
4. 差异的非 “正常查询变化” 说明
正常查询的差异仅由 ID 值不同导致；而异常输入产生的差异，是因为 SQL 语句结构被污染，属于执行逻辑被篡改，并非正常业务查询变化。
任务 3：机制分析与差异比较
1. 输入进入查询结构的完整链条
用户输入 → 直接拼接 SQL → 数据库解析执行被篡改的语句 → 返回异常结果
2. 根因是 “结构被污染” 而非 “字符本身危险”
单引号'等字符本身不危险，其作用是界定 SQL 字符串边界。
漏洞根因是：输入被当作代码执行，污染了 SQL 结构，而非字符危险。
若使用参数化查询，输入会被视为纯数据，无法改变语句结构，注入失效。
3. Low 与 Medium 级别差异

维度	Low	Medium
处理方式	直接拼接，无过滤	使用 mysql_real_escape_string 转义特殊字符
注入类型	字符型注入直接成功	字符型被拦截，常为数字型注入
SQL 示例	WHERE user_id = ’$input’	WHERE user_id = $input

4. 普通 SQL 注入与盲注差异

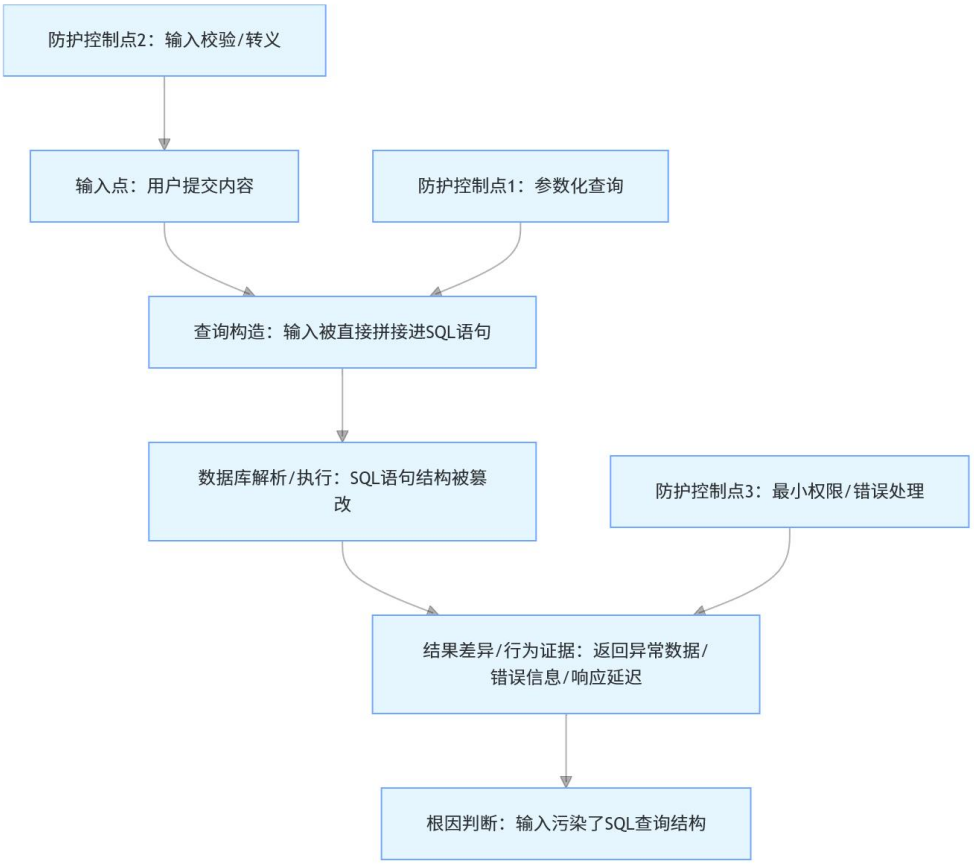
维度	普通 SQL 注入	Blind SQL Injection
页面反馈	直接返回数据 / 报错	仅返回成功 / 失败状态
判断方式	直接读取结果	布尔判断、时间延迟判断
效率	高	低，需逐位猜解

5. 盲注与普通注入根因相同、证据形式不同
二者根因完全一致：输入污染 SQL 结构。
区别仅在于证据形式：
普通注入：直接显示数据 / 报错。
盲注：通过页面状态、响应时间间接判断。
强制判断题
答案：B. 输入进入了不该进入的查询结构
理由：SQL 注入的本质是输入被当作代码执行，污染查询结构，而非字符本身危险。
答案：B. 证据形式不同
理由：普通注入与盲注根因相同，仅漏洞表现与验证方式不同。
任务 4：SQL 注入防护清单与解释

防护措施	解决的问题	控制层级	不能替代的措施
参数化查询（预编译）	从源头阻止输入污染 SQL 结构	**根因防护**	无法解决权限、业务逻辑漏洞
输入校验	限制输入格式、长度、	暴露面	不能替代参数化，可被绕

防护措施	解决的问题	控制层级	不能替代的措施
	类型	收敛	过
错误信息屏蔽	避免泄露数据库结构	暴露面收敛	不能阻止注入，仅降低攻击效率
最小权限原则	限制数据库账号操作范围	后果控制	不能阻止注入，仅降低危害
输入转义	转义特殊字符，避免闭合	辅助防护	复杂场景仍可绕过，非根因方案

收口项 1：SQL 注入因果链 / 防护关系图



收口项 2：学生自评表

我本章最清楚的一点：SQL 注入的根因是输入污染 SQL 查询结构，而非特殊字符本身危险。

我最容易混淆的一点：盲注与普通注入的证据形式不同，但根因完全相同。

我本次作业最需要教师复核的部分：Low/Medium 级别防护差异、盲注原理理解。

如果重做，我会优先补充：各安全级别注入实验截图与逐张分析。

收口项 3：AI 输出审核与人工复核记录

AI 辅助完成：报告框架、术语规范、逻辑梳理。

本人复核保留：根因分析、防护层级、盲注与普通注入对比。

修正 AI 不准确内容：统一 DVWA Medium 级别转义逻辑、明确参数化查询的根因地位。
最终确认方式：结合 DVWA 实际实验输入输出，逐点验证结论与现象一致，确保严谨无误。